APPOINTMENTS — PRODUCTION READINESS & QA REPORT

МедТермин · 12 November 2026 · Pre-release assessment

Audit reference	Value
Application revision	`08bd3d62c246eb8b8b6586d46357f2db50ba9fb0` on `main`
Overall verdict	**NOT READY for unrestricted production release**
Confirmed high-priority issue	Staff workspace becomes unresponsive with a plausible accumulated clinic dataset
Findings	0 Critical; 1 High; 8 Medium; 4 Low. Some are explicitly identified policy, documentation or code-only risks rather than reproduced application defects.
Product changes during audit	**None.** Only audit material, audit harnesses and two corrections to existing browser tests.
Data safety	Disposable local databases and synthetic identities only; no production database accessed or changed.

> **RELEASE VERDICT: NOT READY**
> Core workflows passed; a reproduced staff-workspace performance issue and remaining acceptance work block unrestricted release.

1. Decision and practical interpretation

The principal booking, identity, tenant-isolation and transaction mechanisms performed well in the executed tests. Concurrent bookings produced one winner, stale edits were rejected, shared patients could not double-book across clinics, and the complete browser booking/confirmation/cancellation flow produced the expected database history and busy-time changes. Restoring the clinical and platform databases also worked.

There is nevertheless a **reproduced release-blocking scalability problem**. After adding 5,000 patients and 30,000 historical appointments to one clinic, a receptionist workspace downloaded approximately **12.1 MB** of bootstrap JSON. Its overview took **21.7 seconds** to become usable, including a **20.5-second JavaScript long task**. The workspace repeats the bootstrap every 20 seconds. The same machine loaded the patient overview in approximately 0.4 seconds. This was an actual Chromium execution, not an estimate from reading code.

Other verified problems include stale-tab logout/language failures, authenticated same-site cross-origin framing, contrast and calendar keyboard-accessibility failures, and missing clinic headers in Swagger's patient

operations. Identity assurance, operational audit coverage and public privacy/terms content also need explicit launch decisions.

This verdict does not mean that the fundamental appointment engine failed. It means the measured staff usability failure and remaining release/security acceptance work prevent a responsible unconditional production sign-off. A controlled synthetic-data staging demonstration is substantially better supported by this evidence than a broad real-patient launch.

Recommended release gates:

1. Resolve H01 and repeat the growth experiment through both API and browser; agree response-size and interaction-time budgets for the expected clinic workload.
2. Address M01–M05, including browser regressions that exercise real clinic workspaces and open dialogs.
3. Decide and document M06–M08 with the company, clinic owners and appropriate privacy/security reviewers. These are not automatically solved by passing functional tests.
4. Complete the production-only checks in section 11 against the actual IIS/domain/database deployment. The environment used for this audit cannot certify them.
5. Re-run the complete regression suite on the final release revision and perform a final staging smoke test. This report assesses the named revision, not future fixes.

---

2. Scope, environment and evidence rules

The repository inventory contains **319 tracked baseline files**, including **157 application files** across API, Web, Core, Contracts and Data. The inventory records paths, sizes and SHA-256 fingerprints. Controllers, domain rules, persistence operations, EF mappings/migrations, shared SQL installation, authentication, tenant routing, browser scripts, styles, Razor pages, configuration, publishing content and CI were examined by component. Compiling or listing a file is not represented as proof of complete line or branch coverage.

Execution used:

- .NET SDK 10.0.100/runtime 10.0.0 on Linux; Release solution build and complete API/Web publish outputs.
- PostgreSQL 17.11 in a container bound only to loopback. A test coordinator created generated clinical/platform databases and ordinary database-owner roles without cluster-administrator privileges.
- Two independently running published API processes and a published Web process in **Production mode**. Local HTTP testing was explicitly enabled, with a generated shared proxy key. Demo data/imports were disabled for the principal fixture.
- Main, east and registration-closed clinic schemas; separate company registry database; shared patient identities; reception, doctor, patient, another patient, and company accounts.
- Chromium 154, Playwright 1.64.1, Node 24.19.0 and axe-core 4.14.0. Existing suites also exercised stubbed MVC integrations and the explicitly enabled Development JSON backend; those are labelled separately.
- Dedicated synthetic history, contacts and accounts. The large-data benchmark records were removed after measurement. Restore databases/dumps and the final fixture were cleaned up as recorded in the evidence.

Status definitions: PASS means the stated assertion was executed successfully, within its stated scope. FAIL means an assertion did not hold; the report distinguishes product failures from test-harness errors. BLOCKED means a concrete environment/dependency prevented verification. NOT TESTED means the scenario was not executed. A passing process exit is not silently substituted for passing assertions.

No claim is made of 100% code coverage, every possible input combination, formal security certification, medical/legal compliance, or production capacity. Every discovered feature family is accounted for in FEATURE_COVERAGE.md; specific remaining combinations are identified there and in section 11.

---

3. Architecture and verified boundaries

```
Browser
  └─ Razor/MVC Web + JavaScript workspace
       ├─ protected clinical or company cookie; CSRF validation
       └─ server-side ApiClient; opaque API token + signed client attribution
            └─ API: authentication, role/ownership, clinic resolution, validation
                 ├─ Core: availability, status and booking rules
                 ├─ Data: EF Core, transactions, version checks, advisory locks
                 ├─ appointments: public / clinic_* / careline_identity
                 └─ appointments_platform: company registry and operator sessions
```

The browser does not connect to PostgreSQL or obtain the API bearer token as a JavaScript credential. Web and API independently enforce boundaries; hiding a navigation item is not the authorization mechanism. Shared patient identity and sessions remain central, while each clinic has its own contact/profile, appointments and staff accounts. Joining another clinic requires an explicit authenticated action. Registering an existing contact email does not transfer that contact's history to the new identity.

Staff sessions remain clinic-bound. A doctor sees their own appointments; a patient sees their own appointments. Doctors are intentionally allowed to create/edit clinic scheduling contacts; this is existing tested policy, not an identified authorization bypass. Clinic owners should explicitly accept that contact-access policy before real deployment. Another clinic's appointment details are not disclosed through the shared busy-time representation.

Concurrency is layered: request-key idempotency, transaction-scoped advisory locks, catalogue/doctor/patient coordination, optimistic record versions, SQL uniqueness and range exclusions, and atomic history writes. Shared patient range exclusions span clinics. The executed cross-instance races and the 225-case status matrix support these boundaries for the tested cases.

Schemas are **namespaces, not separate database-security sandboxes**. The clinical runtime owner can reach multiple schemas. The API is the tenant authorization boundary; a compromised shared database credential would have broad impact. Production role/network/secret controls remain an operational acceptance requirement.

4. Build, dependency and automated execution results

The Release solution build and both complete publish outputs succeeded with **zero build warnings and zero errors**. JSON/XML/JavaScript/Python syntax checks passed, and the generated English catalogue check verified 1,156 messages. NuGet's vulnerability check and npm audit reported no known vulnerable packages in their covered dependency sets at audit time. That is not proof that every bundled asset, runtime, OS component or future advisory is safe; see L04.

Executed suite	Final result and scope	Evidence
Core executable	107/107 PASS: scheduling, ownership, status rules, persistence, limits, dates, import metadata	`logs/baseline-core.log`
Frontend DOM/language/password/theme/dates	All PASS: 85 DOM, 23 language, 16 password, 14 theme, 42 date assertions	`logs/baseline-dom.log`
PostgreSQL/API/MVC	126/126 PASS, plus direct SQL/upgrade/patient-number probes and a repeated DOM invocation	`logs/baseline-api.log`
Multi-tenancy	75/75 API/MVC plus 12/12 DOM PASS	`logs/baseline-tenancy.log`
Platform/public discovery	103/103 PASS, including provisioning/adoption/restart cases	`logs/baseline-platform.log`
Shared patients	Original run FAIL due to stale test expectation; corrected full run 64 API + 30 browser PASS	`logs/baseline-global.log`, `logs/global-revalidated.log`
Booking review	21 API + 22 real-browser PASS	`logs/baseline-booking.log`
Historical high-severity regressions	65/65 PASS, including real TLS, registry outages, concurrency, preview safety and maintenance	`logs/baseline-high.log`
Tester feedback	Original run FAIL due to resize timing; corrected full run 52 browser checks and database check PASS	`logs/baseline-feedback.log`, `logs/feedback-revalidated.log`
Tester round two	40 API/database + 59 browser PASS	`logs/baseline-round2.log`
Overnight regressions	8 API + 11 browser PASS	`logs/baseline-overnight.log`
Discovery/settings/language/themes	89 MVC contract, 138 browser, 87 settings, 72 language, 46 theme PASS; public API stub/JSON scopes identified in log	`logs/baseline-discovery.log`
Existing accessibility suite	17/17 PASS on its demo/default-theme scenarios; **does not supersede new real-data failures**	`logs/baseline-accessibility.log`

Executed suite	Final result and scope	Evidence
MVC HTTP smoke	38/38 PASS	`logs/baseline-http.log`
New OpenAPI-driven matrix	**379/379 PASS**, 53 method/path operations plus method/auth/validation/search/race assertions	`evidence/api-matrix-results.json`
New actual-schema check/FK probes	**46/46 PASS**	`evidence/database-probe-results.json`
New column/key/exclusion/cascade probes	**266/266 PASS**	`evidence/database-column-key-results.json`
New role/session/cross-clinic security checks	**76/76 PASS**; includes observation of unverified registration, not an assurance endorsement	`evidence/security-results.json`
New exhaustive status matrix	**225/225 PASS**, role × current status × requested status × time phase, with DB assertions	`evidence/status-matrix.json`
New real-database browser scenarios	**49 PASS / 11 FAIL** out of 60 assertions; failures map to M01–M04	`evidence/browser-targeted.json`
Physical drag, stored HTML, repeated drawer resize	**3/3 PASS** on final synchronized run; invalid off-grid drop also rejected safely	`evidence/browser-extra.json`, `evidence/calendar-off-grid-rejection.json`
Growth API measurements	7 measurement groups PASS for HTTP completion; **performance acceptance FAIL, H01**	`evidence/performance.json`
Growth browser measurements	Both overview renders completed; staff timing/long task **FAIL release acceptance, H01**	`evidence/browser-performance.json`
Paired backup/restore	**11/11 PASS**, including restored authentication, migration and new booking	`evidence/restore-results.json`
Additional Core probes	1 PASS / 1 FAIL: source preference ignored; JSON idempotency discrepancy L01	`logs/core-additional-final.log`
Syntax/configuration	108 tracked-file checks PASS, plus build/localization validation	`evidence/syntax-all.json`

Counts above are assertion or scenario counts, **not unique code branches**. Some suites deliberately repeat common setup/DOM assertions. TEST_LEDGER.csv preserves each recorded execution with its evidence location rather than inflating a single "coverage percentage".

Test-harness corrections and unsuccessful attempts

Two existing tests were corrected without touching product code:

1. The old global-patient CSRF assertion posted patient creation as a patient. Authorization now correctly returns 403 before CSRF validation. The replacement submits a valid patient-allowed booking with the stale clinic CSRF token and verifies **400**, so it actually isolates CSRF.
2. The drawer test asserted state immediately after resizing. It now waits for the browser's media-query handler. A further 20 physical phone/desktop transitions passed.

Two inapplicable guarded patient probes issued no request; they are excluded from the 76 meaningful security assertions and marked NOT TESTED in the ledger. Audit harness attempts also required corrections for role-route prefix classification, PostgreSQL identity-always versus identity-by-default errors, JSON booleans, selector synchronization, a recovery-query column name, rate-budget/timing interactions, and local SDK activation. Early restore attempts successfully restored fingerprints but did not finish application startup because of harness environment access/PATH errors. The final 11-case restore run passed. Early drag attempts landed on 10:40, outside the 30-minute provider grid; the API correctly returned 409 and preserved the appointment. The corrected physical drag to 10:30 passed. Logs of unsuccessful attempts are retained. These are not silently reported as application defects or unqualified passes.

---

5. Database audit and restore verification

This section describes **actual test-database catalogues after application migration**, not an assumption that migration source equals the live production schema.

Area	Actual observed structure
Clinical database	55 tables: 16 each in `public`, `clinic_east`, `clinic_closed`; 7 in `careline_identity`
Clinical constraints/indexes	166 validated constraints; 131 indexes valid and ready
Canonical clinic tables	Accounts, AppointmentHistory, Appointments, AuditEvents, AvailabilityExceptions, DoctorServices, Doctors, IdempotencyRequests, Patients, Services, Sessions, Settings, SourceSchedules, Specialties, WorkingPeriods, `__EFMigrationsHistory`
Shared identity tables	`clinics`, `accounts`, PatientAccounts, PatientSessions, PatientMemberships, PatientBookings, PatientEvents
Platform database	PlatformClinics, PlatformOperators, PlatformSessions, PlatformSchemaVersions
EF clinical migrations	Seven applied; zero pending migrations; `HasPendingModelChanges=false`
Model/catalogue comparison	All 156 mapped columns exist with matching nullability; exact actual/model types retained for inspection

Area	Actual observed structure
Shared installation	SQL scripts 008/009 and attached identity/busy-time triggers inspected in the installed database; these are not ordinary per-clinic EF migrations

The DATABASE_CATALOGUE.md appendix lists every observed table, column/type/default/nullability, constraint and index, with complete JSON for trigger/function/grant definitions. It includes generated tenant copies and distinguishes EF-managed and shared/manual installation.

Rollback probes exercised canonical non-null and bounded-string columns, primary keys, unique indexes, foreign keys, checks, doctor/patient/shared range exclusions, role/profile links and session cascades. Tenant copies were catalogued and exercised through tenant-specific API/browser flows; mutation-testing every identical constraint in every schema was not claimed. Each failure probe verified an actual affected row and the relevant PostgreSQL error/constraint instead of passing on an empty update.

Range conflicts, cancelled-slot reuse, current-version history, duplicate registration, contact/email normalization, clinic patient-number assignment, service relations, schedule/date validity and active-administrator safeguards also ran through the application. Cross-schema identity/membership relations that cannot be expressed as one fixed tenant FK are protected by explicit binding/identity checks and triggers; this remains an important architectural boundary.

The restore rehearsal made full custom-format backups of both generated databases during a checked, stable-data window. **Every one of the 55 clinical and four platform tables matched its restored row-count and content fingerprint.** The source pair remained unchanged during the backup window. The restored pair then passed complete maintenance validation; main/east/shared-patient/company logins and a new appointment/history write worked. That restored write was absent from the source. Temporary restore databases and raw dumps were deleted.

This demonstrates a local logical restore, **not** a hot cross-database atomic-backup guarantee, production point-in-time recovery, Windows disaster recovery, role/secret restoration on a new server, or the actual organization's recovery-time objective. See section 11.

---

6. API, business rules and role coverage

API_COVERAGE.md enumerates the **49 OpenAPI paths / 53 method-path operations**, including health/minimal endpoints, with anonymous, invalid-session, authorized-read and selected wrong-role results. The audit additionally exercised Swagger UI/assets, schema retrieval and unsupported methods. Positive write paths are supported by the named integration/browser suites; the endpoint matrix itself is not misrepresented as executing every write with valid data.

Executed negative cases included missing/invalid bodies, null/list/string JSON, overlong fields, absent phone/email, invalid emails/phones, unknown profiles, unsupported roles/statuses, invalid versions, malformed/maximum dates, backwards ranges, excessive page sizes, non-existent records, clinic-header injection strings, Cyrillic names, SQL-style search text and HTML search text. No uncontrolled 500 response was observed in that targeted matrix. This does not imply every possible malformed HTTP message was tested.

Real two-host races covered identical booking retries, different requests for one doctor/time, one patient across doctors, shared patients across clinics, stale reschedules, stale schedule/contact/catalogue edits, account

changes, administrator disabling and registration/provisioning. Appointment history and shared busy-time assertions verified the durable result, not just HTTP status.

Appointment status coverage

All five statuses are present: **Scheduled / Чека потврда**, **Confirmed / Потврден**, **Completed / Завршен**, **Cancelled / Откажан**, **NoShow / Не се појавил**.

The 225-case matrix independently exercised three roles, every source/target status and future/in-progress/past phases. Accepted transitions incremented version and appended one history row; rejected transitions left status/version/history unchanged. Shared busy records followed Scheduled/Confirmed and were absent after terminal outcomes.

- Confirmation-required doctors create Scheduled requests; ordinary and explicitly agreed receptionist bookings create Confirmed visits.
- Staff can confirm future Scheduled requests; patients cannot elevate status.
- Own future Scheduled/Confirmed appointments can be cancelled according to role/ownership.
- Staff can resolve overdue Scheduled requests by cancellation, and by completion/no-show after their end.
- Completion/no-show is permitted for appropriate staff after the appointment ends; terminal states cannot be reopened.
- Rescheduling preserves ownership, checks versions/conflicts/current booking restrictions and reevaluates confirmation policy. Patient self-service is blocked for reception-only/by-agreement doctors; authorized reception can record an agreed time without fabricating a weekly schedule.

Other verified boundaries include 180-day booking horizon, 31-day availability/calendar queries, service-based duration, variable/dated weekly schedules, exceptions/absence conflicts, duplicate exception protection, patient booking quotas, DST invalid/ambiguous periods, last-safe-administrator protection and import-text independence. Imported `TuesdayFirst`/notes do not control business policy; the dedicated additional probe returned Wednesday slots despite that legacy flag.

---

7. Findings, reproductions and recommended fixes

Severity reflects demonstrated impact and scope. "Observed gap" is not synonymous with an exploitable authentication bypass. Exact response details, selectors and measurements remain in the linked evidence.

H01 — Unbounded staff bootstrap and repeated whole-history date formatting freeze the workspace

HIGH · reproduced in API, Chromium and database · open

Affected: `src/Appointments.Data/PostgresAppointments.cs:14–19`; `src/Appointments.Web/wwwroot/js/app.js:97–112`, `:304–308`, `:382–390`, `:1947–1970`; `GET /api/bootstrap` and Web `GET /data/bootstrap`. All historical appointments and all scheduling contacts are fetched for staff; UI pagination does not bound that payload. `wall()` constructs a fresh `Intl.DateTimeFormat` per conversion, and overview calculations repeatedly scan the full appointment array.

Reproduce: use the disposable fixture; run `performance_20261112.py`, which adds 5,000 contacts/30,000 completed historical visits; run `browser_performance_20261112.cjs`; sign in as reception and open the overview. Do not run this synthetic workload against production.

Observed: 12,107,744 bytes for one staff bootstrap; local API median 379.76 ms, p95 522.58 ms; 24 requests at concurrency eight had p95 2,178.3 ms and all returned 200. Browser overview readiness was **21,685 ms**, with a **20,517 ms main-thread task**. Patient readiness was 398 ms. A paged 12-item appointment response was 4,439 bytes/median 33.35 ms. Under an explicit 20-staff/20-second polling assumption, bootstrap alone is about **12.1 MB/s uncompressed aggregate transfer**. This is an arithmetic workload illustration, not a measured production network limit.

Impact: receptionist controls can be unusable for tens of seconds; repeated polling transfers and processes the entire history as the clinic grows. API-only latency would have missed the most serious effect.

Fix: split bootstrap metadata/current aggregates from history; load appointments and contacts using server-side filters/pagination and bounded calendar windows; use server-side overview totals. Cache/reuse timezone formatters and converted local dates within a render. Avoid rerendering unchanged summaries; pause/back off polling appropriately. Compression alone does not fix CPU or unbounded growth. Add a real-browser growth regression and agree budgets before retesting.

Evidence: `evidence/performance.json`, `browser-performance.json`, `performance-row-counts.json`, `query-plans.json`; `screenshots/large-reception-overview.png`.

M01 — Older patient tabs cannot log out or change language after a clinic switch

MEDIUM · reproduced · open

Affected: `src/Appointments.Web/Services/ClinicAntiforgery.cs:8–25`; shared account/settings forms in `_AccountSettings.cshtml` and `_LanguageSelector.cshtml`; `POST /Account/Logout`, `POST /Preferences/Language`.

Reproduce: log a shared patient into main in tab A. In tab B select east from My clinics. In A open account settings and click Logout, or repeat with English language selection. **Actual: HTTP 400.** A stale clinical `/data/bootstrap` read returns 409 as intended.

Cause: workspace forms carry the issuing clinic's additional CSRF data. Personal endpoint validation accepts the personal identity token or the *current* clinic token, so the old main token is rejected after the cookie changes to east.

Fix: issue personal-identity-bound tokens for global account controls regardless of which clinic rendered them, while preserving strict clinic binding on clinical writes. Keep the underlying antiforgery identity check and add two-tab logout/language regressions. Refreshing the old tab is a workaround, not a fix.

Evidence: `browser-targeted.json` B002/B003; `screenshots/stale-tab-logout.png`.

M02 — Authenticated workspace permits same-site cross-origin framing

MEDIUM · browser-proven, scope qualified · open

Affected: Web response-header pipeline, `src/Appointments.Web/Program.cs:110`; `/Workspace` and other sensitive MVC pages.

Reproduce: authenticate on one loopback port, then open a different-origin page on another loopback port containing an iframe to `/Workspace`. The authenticated overview renders inside the frame. The workspace response had **neither X-Frame-Options nor CSP frame-ancestors**.

Impact/scope: enables UI-redress/clickjacking where an attacker controls another same-site origin, such as an untrusted sibling application. The demonstration was same-site/different-port. SameSite=Strict cookies reduce unrelated cross-site authenticated framing; this test does **not** prove that an arbitrary unrelated domain receives the login cookie. No XSS or token extraction was demonstrated.

Fix: establish a response-level framing policy, normally `Content-Security-Policy: frame-ancestors 'none'` and an appropriate legacy X-Frame-Options policy. Test intended embedding exceptions explicitly. A parent-framing policy does not itself prohibit the app's child Google Maps iframe; assess any broader CSP separately.

Evidence: `browser-targeted.json` B059; `screenshots/authenticated-cross-origin-frame.png`.

M03 — Default-theme contrast failures remain in real workspaces and dialogs

MEDIUM · axe/browser reproduced · open

Affected: `src/Appointments.Web/wwwroot/css/site.css:764–768`, `:1609–1618`, `:1647–1664`, `:2789–2796`; real-clinic breadcrumb, booking review, availability summaries; company recovery warning styling around `:375–386`. Relevant markup includes `Views/Home/Workspace.cshtml`, `Views/PatientSupport/Index.cshtml` and booking DOM in `app.js`.

Reproduce: sign in as reception/doctor with actual clinic metadata; inspect the current clinic name in Standard theme. Open a booking review and the company patient-recovery form. Run the supplied axe scenarios.

Examples: static clinic breadcrumb **1.81:1** (#bac3b7 on approximately white); booking step **4.48:1**, booking specialty **4.25:1**, recovery warning **4.38:1**, where these normal-size texts require 4.5:1 under the tested WCAG AA rules. Dark/Vibrant doctor-card scans passed their exercised scenarios; no claim is made that all theme/state combinations passed.

Fix: correct semantic text tokens and specificity rather than changing every background. In particular `.breadcrumb span` overrides the intended clinic-name color. Retest all roles, three themes, dialogs and disabled/error states. Existing demo-only accessibility passes did not cover the real clinic breadcrumb.

Evidence: `browser-targeted.json` contains exact selectors, colors and ratios for every reported node; 22 additional axe scans were executed.

M04 — Calendar scroll region is not keyboard-focusable in an exercised state

MEDIUM · automated browser finding · open; manual assistive-technology assessment outstanding

Affected: FullCalendar `.fc-scroller-liquid-absolute`; calendar initialization in `src/Appointments.Web/wwwroot/js/app.js:1210–1255`, calendar markup around `:1150–1165`, scroll styling `site.css:2289`.

Reproduce: open reception Calendar with the QA fixture and run WCAG A/AA axe checks. `scrollable-region-focusable` reports the time-grid scroller. Pointer interaction and an actual drag/reschedule passed separately. The app also offers appointment-list keyboard access, so this is not evidence that every appointment workflow is inaccessible.

Fix: provide a keyboard-focusable, labelled scroll region or supported FullCalendar keyboard behavior, preserving a visible focus indicator and meaningful navigation. Verify scrolling timeslots with keyboard and a

real screen reader, including empty calendars and mobile layouts.

Evidence: `browser-targeted.json` B029, plus the successful physical drag in `browser-extra.json`.

M05 — Swagger omits required X-Clinic input from patient CRUD operations

MEDIUM · schema and live request reproduced · open

Affected: `src/Appointments.Api/Services/ApiDocumentation.cs:35–45`; POST `/api/patients`, GET/POST `/api/patients/{id}`.

Reproduce: inspect `/openapi/v1.json` or authorize in Swagger in a multi-clinic deployment and try patient details. Those operations lack an X-Clinic parameter. A valid reception token without clinic selection returned **400**; the same request with `X-Clinic: main` returned **200**.

Cause: `StartsWith("/api/patient")` intended for central `/api/patient/...` also matches clinic-local `/api/patients...`.

Fix: distinguish the singular patient-account route using a segment boundary, then assert the required header for **every** clinic-scoped OpenAPI operation. Authorization and tenant routing themselves remained enforced; this is not a cross-clinic data leak.

Evidence: `evidence/swagger-header-defect.json`, `openapi.json`; the older general Swagger assertion passed because it sampled other scoped operations.

M06 — Operational audit does not cover a complete security/access trail

MEDIUM · database observation plus code review · policy/engineering gap

Affected: `src/Appointments.Api/Services/GlobalPatients.cs:22–58`, `PlatformService.cs:48–68` and metadata updates; `AccountService.cs:19–58`; read endpoints in `PostgresAppointments.cs`; `AppointmentsDbContext.cs` AuditEvents mapping and `database/009-global-patients.sql` PatientEvents.

Observed: eight rejected patient login attempts and lockout were executed. The patient's persistent events showed registration/session creation, without corresponding failure/lockout events. Successful booking/contact/account changes do have transaction-associated operational events/history. Patient-record reads are not a complete access trail; there is no comprehensive company-action audit ledger, externally protected audit sink, retention job or tamper-evident design in this repository.

Impact: investigating credential attacks, operator actions and sensitive-record access is limited. This is not a finding that appointment history is absent or that every failed request disappears from infrastructure logs; production log aggregation was unavailable.

Fix: agree event scope, retention and access policy; add structured failure/lockout/operator/access events without credentials or unnecessary medical/contact payloads; send protected operational logs to an appropriate sink; validate correlation/alerting and retention. Do not claim compliance merely by adding a table.

Evidence: `evidence/patient-audit-actions.json`, `security-results.json`, installed audit tables/functions and the cited source.

M07 — Email/phone ownership assurance and MFA are not implemented

MEDIUM · confirmed product-scope gap; requires owner decision

Affected: `GlobalPatients.cs:77–94`, `AccountService.cs:19–58`, `PlatformService.cs:48–68`; registration/login contracts and views.

Reproduce: register a synthetic `.test` mailbox and phone and sign in immediately. There is no email/SMS ownership challenge. Staff/company sign-in has password/session/rate-limit/lockout protections, but no MFA challenge.

Scope: form format validation, password hashing, lockout and tenant ownership passed. An unverified mailbox did **not** gain an existing clinic contact's history; that isolation passed. The app does not claim to send reminders or recovery email. Absence of MFA is a risk decision, not by itself proof of a broken authentication mechanism.

Fix: define identity-assurance requirements for patients and privileged staff. Implement verified-address/contact workflows and appropriate privileged-account MFA or approved identity-provider integration if required by that policy. Keep manual recovery identity verification explicit and auditable; test recovery end to end through the actual chosen provider.

M08 — Public privacy and terms are intentionally unpublished placeholders

MEDIUM · reproduced markup/product gap; previously deferred design scope

Affected: `src/Appointments.Web/Views/Discover/Index.cshtml:172`; footer privacy/terms controls show "Наскоро" with `aria-disabled=true`. No corresponding implemented policy pages were discovered.

Reproduce: open the landing footer; the displayed policy items cannot be opened. This is not a broken promise that an already-approved policy page existed; placeholders were intentionally accepted during development.

Fix before real-data launch: obtain approved content and clear operator/contact responsibilities; publish accessible pages and any required consent/notice flows. A technical audit cannot authoritatively determine the applicable legal obligations or approve this deferral.

L01 — JSON demo idempotency ignores a changed AgreedTime flag

LOW · executable reproduction; Development-only backend

Affected: `src/Appointments.Core/AppointmentService.cs:61–68`. PostgreSQL's separate complete-command fingerprint implementation in `PostgresAppointments.cs:101–115` handles the field correctly.

Reproduce: in the JSON backend, book a confirmation-required provider as reception with `AgreedTime=false`; retry the same request key with identical fields and `AgreedTime=true`. The old Scheduled result is replayed rather than a changed-command 409. `tests/audit/CoreProbes` reproduces it and exits nonzero for that observation.

Fix: include the complete canonical booking command in demo idempotency comparison, or explicitly include AgreedTime with a regression. Production PostgreSQL behavior was not found to share this defect.

L02 — API documentation contains obsolete patient and health guidance

LOW · code/document discrepancy

Affected: `docs/API.md:31`, clinical patient-creation row, and `:72`, "Errors and health" paragraph. It still describes email/phone as optional on patient creation and `/health` as process-only liveness. Current contract requires both on new manual patients; `/health/live` is liveness, while `/health` checks readiness/shared-store access. The executable checks observed the current behavior.

Fix: update examples/health semantics and distinguish new-patient creation from legacy contact editing. Add lightweight documentation assertions where stable. Incorrect monitoring guidance can hide or mislabel a deployment failure.

L03 — Per-schema connection-pool growth needs a multi-clinic capacity budget

LOW · architectural/code-only concern, not a reproduced outage

Affected: `src/Appointments.Api/Services/SharedClinicDatabase.cs:20–39`, `ClinicConnections.cs`, `PublicDiscovery.cs:69–111`, registry/startup paths. SearchPath changes the connection string per clinic, producing distinct Npgsql pools. Public multi-clinic discovery traverses selected clinic connections sequentially.

Risk: as tenant count and API-instance count grow, aggregate connections/latency may exceed a shared PostgreSQL budget even with low individual-clinic traffic. The audit exercised multiple clinics/hosts, **not** hundreds of active schemas or a pool-exhaustion campaign.

Recommendation: define aggregate pool limits, timeouts, eviction/idle policy and discovery latency budgets; load-test the intended tenant count against the intended PostgreSQL `max_connections` and infrastructure. Consider a supported shared-data-source approach with safe per-transaction schema selection if architectural work is justified; never trade away binding checks casually.

L04 — Automated assurance does not yet cover all dependencies and exercised states

LOW · code/CI observation and demonstrated test blind spots

Affected: `.github/workflows/ci.yml`, `tests/frontend/accessibility-browser.cjs`, `src/Appointments.Web/wwwroot/vendor/fullcalendar.min.js` (Standard Bundle 6.1.20), frontend test manifest.

NuGet/npm advisory checks were run for this audit but are not a comprehensive enforced release gate. Vendored FullCalendar is outside the test package manager's dependency graph. Existing accessibility checks use demo scenarios and missed the real-clinic breadcrumb/dialog failures. Two existing tests also needed the narrow corrections recorded in section 4; they are corrected in this audit, not left as known failures.

Recommendation: add representative real-database accessibility/dialog/growth cases to CI, maintain a vendored-asset inventory/advisory review, pin/maintain build actions according to company policy, and publish build/test/advisory artifacts. No known FullCalendar vulnerability is asserted by this finding.

---

8. Security and reliability conclusions within tested scope

Passed evidence includes role and object-level denial, clinic-bound staff sessions, explicit patient joining, no automatic history transfer by matching email, persistent distributed lockouts for all three identity classes, expired/revoked-session rejection, password-change/session revocation, same-origin CSRF and stale-clinic write protection, safe return URLs, body/date bounds, parameterized query use and HTML escaping in the exercised stored-name flow.

Transport regressions executed a real local TLS listener with certificate validation and verified fail-closed HTTP behavior when secure configuration is required. Trusted-proxy attribution was exercised with valid and invalid signatures, independent visitor budgets and structured 429 responses. These results **do not** establish that IIS forwarding, external TLS termination, cookies, firewalls or key storage are correctly configured on the real server.

Registry-outage tests checked a brief cached-routing lease, eventual fail-closed behavior and recovery without restart. Booking and maintenance tests verified idempotent outcomes, consistent histories and no automatic JSON fallback on backend failure. Natural multi-hour session expiry, long soak tests, power loss and production failover were not executed.

9. Performance evidence and limits

Measurement	Median	p95	Decoded response bytes
Small reception bootstrap, 10 sequential samples	54.83 ms	90.84 ms	9,414
Large reception bootstrap, 10 samples	379.76 ms	522.58 ms	12,107,744
Large doctor bootstrap, 10 samples	328.37 ms	506.84 ms	12,107,730
Large patient bootstrap, 10 samples	41.91 ms	47.48 ms	6,127
Large paged appointments, take 12	33.35 ms	34.59 ms	4,439
Large reception bootstrap, 24 samples / concurrency 8	1,418.28 ms	2,178.3 ms	approximately 12.1 MB each
Large next-slot summary, 5 samples	37.93 ms	46.97 ms	258

These are local, bounded experiments on shared test hardware, not clean-room benchmarks or production SLAs. Some browser exploration overlapped the API measurements. The historical workload was synthetic completed visits, without generating 30,000 history/audit records or real medical data; row shape and dataset counts are explicit in the seeder/evidence. Slow WAN links, mobile CPU, realistic multi-clinic distribution, backups under load and sustained occupancy may behave differently. The browser measurements are single observations, not p95 browser statistics.

Observed query plans, index metadata and row counts are retained. Index validity and selected indexed queries do not establish that every production query is optimal.

10. Prioritized remediation and acceptance plan

Priority	Work	Acceptance evidence required
P0	H01 bounded staff loading and rendering	Repeat the same growth dataset; bounded transfer, no multi-second blocking task; all counts/history/filters remain correct
P1	M02 frame policy	Same-site cross-origin frame refused, normal pages/Maps still work
P1	M01 personal-token behavior	Two-tab logout/language succeed; stale clinical read/write remain blocked
P1	M03/M04 accessibility	Axe passes representative real-data states; manual keyboard and screen-reader verification
P1	M05 OpenAPI	Every scoped operation exposes clinic selection and works in Swagger with valid authorized input
Before real-data launch	M06–M08 decisions and implementation	Documented audit/assurance/content acceptance; tests of chosen providers and operational controls
P2	L01/L02	Demo retry conflicts on changed flag; API/monitoring documentation matches contracts
P2	L03/L04	Tenant capacity budget and load evidence; dependency/state coverage included in release checks

No application fixes or architectural refactors were made during this audit. Recommended implementation should be reviewed as a subsequent change set and assessed at its own revision.

11. Explicit coverage gaps and deployment blockers

Area	Status	Why / evidence needed
Actual `medtermin.mk`, app/admin/api DNS, public certificates and redirects	**BLOCKED**	A direct HTTPS HEAD attempt was rejected by this environment's outbound CONNECT proxy with 403. That is an environment restriction, not evidence that the public app is broken.

Area	Status	Why / evidence needed
Actual production PostgreSQL schema/data/roles at the company's server	**BLOCKED**	No verified current production audit connection was available through this environment’s configured network access. Generated local schema cannot certify production drift.
Windows/IIS Hosting Bundle, bindings, app-pool identity, filesystem ACLs and recycle behavior	**BLOCKED**	Execution host is Linux; no Windows/IIS control session. Published outputs built successfully, but this is not an IIS deployment test.
Production reverse proxy, real-client rate-limit attribution, cookie Secure flags and HTTPS backend	**BLOCKED**	Local positive/negative TLS/proxy tests passed; actual topology unavailable.
Production secret storage, rotation, backups of config/Data Protection keys	**BLOCKED**	Server configuration/secret store unavailable. Confirm persistent protected keys, least-privilege storage and restore process without revealing secrets in reports.
Live Maps/third-party pages and social navigation	**BLOCKED** for external execution	Local rendering/encoded URLs/fallbacks exercised; external tiles/geocoding and external destination accuracy cannot be certified here.
Email/SMS delivery, verification, reminders, calendar-provider sync	**NOT TESTED / not implemented integration**	No configured delivery/sync provider discovered. UI explicitly warns that notifications are not sent. Do not advertise these as passing features.
Natural two-hour expiry/long lockout waits	**NOT TESTED** as wall-clock waits	Expired timestamps/lockouts and revocation were tested using controlled test-state changes; no claim of waiting full durations.
Real Safari/iOS, Firefox, Edge/Android devices, touch drag and OS-native controls	**NOT TESTED**	Chromium desktop/responsive widths were used. A narrow viewport is not a physical-device/browser certification.
Real screen readers, human comprehension, complete tab order/zoom/motion assessment	**NOT TESTED** comprehensively	Automated axe, keyboard and viewport tests cover selected states; manual accessibility acceptance remains.
Hundreds of clinics, long-running soak, sustained heavy bookings and connection exhaustion	**NOT TESTED**	Two API processes, bounded races, several clinics and one growth fixture were tested. No speculative capacity number is approved.
Disk-full, process/power loss during commit, storage corruption, backup failure, failover/PITR and network partition	**NOT TESTED**	Local logical restore and selected controlled service failures passed; infrastructure fault certification not available.

Area	Status	Why / evidence needed
Hot cross-database consistent backup, new-server role/password restoration and RTO/RPO	**NOT TESTED**	Restore used an explicitly stable-data window and existing generated roles. Production recovery requires a separate runbook drill.
Formal code/branch coverage, full protocol fuzzing and exhaustive penetration testing	**NOT TESTED**	Assertions and route coverage are listed; no instrumented coverage percentage or accredited penetration-test claim.
Every arbitrary data value/theme/dialog/device combination	**NOT TESTED**	Feature-level coverage and recorded interactions are explicit; combinatorial completeness is not claimed.

Patient deletion remains intentionally unavailable to preserve history, as requested earlier. Reception cannot create/link global patient credentials, and by-agreement doctors cannot be self-booked by patients; these are current product policies, not missing-functionality bugs. Production test-data cleanup and clinic migration strategy require their own approved operational plan; this audit did not modify existing environments.

---

12. Evidence package and reproduction

- Feature inventory and testing checklist
- Every documented API operation and its recorded boundary results
- Actual database structure and integrity coverage
- Individual assertion ledger, test runs and attempt adjudication
- Machine-readable results, raw logs, screenshots
- Audit harness instructions

The evidence manifest records file hashes. Private credentials, session tokens, raw database dumps and runtime configuration files are excluded. Screenshots and persisted data are synthetic. Production issues found after this revision or outside the tested environment remain possible; a final deployment smoke test and operational acceptance are still required.